

Brightcare_Architecture.pdf

Brightcare Digital Health · Confidential · For underwriting use only

SYSTEM & NETWORK ARCHITECTURE SUMMARY

Brightcare Digital Health — Cyber underwriting exhibit

Document ID: BC-ARCH-2026-Q3 | Revision: 3.2 | Dated: 2026-08-14

CONFIDENTIAL — For underwriting and broker use only. Not for redistribution.

1. PURPOSE

High-level architecture for cyber underwriting review. Depicts trust boundaries, identity planes, data stores holding ePHI, and recovery paths.

2. TRUST BOUNDARIES

Internet !' Cloudflare WAF / CDN !' AWS ALB (TLS 1.2+) !' EKS (prod)
Corporate: Zscaler ZPA + Okta SSO; legacy OpenVPN gateway (BOS-R1)
still present for one regional ops VLAN (remediation in flight).

3. IDENTITY & ACCESS

Workforce IdP: Okta (OIDC/SAML). Privileged access: CyberArk PAM + just-in-time roles. Break-glass accounts: offline escrow, quarterly test.
Customer IdP: optional SAML/OIDC federation; default Auth0 for B2B admins.

4. APPLICATION TIERS (PROD)

Edge: Cloudflare !' ALB !' NGINX ingress
Compute: EKS (prod-a, prod-b) — microservices; no SSH from internet
Data: Aurora PostgreSQL (encrypted), ElastiCache Redis, S3 (SSE-KMS)
Analytics: Snowflake (separate account; ePHI minimized / tokenized)
Secrets: AWS Secrets Manager; no long-lived keys in CI artifacts

5. SECURITY CONTROLS (IN-PATH)

EDR: CrowdStrike Falcon on servers + employee endpoints
Network: VPC segmentation; security groups least-privilege; GuardDuty
Email: Microsoft 365 + Proofpoint TAP
Logging: Central SIEM (Splunk Cloud); 365-day hot / 1-year cold

6. BACKUP & DR TOPOLOGY

Continuous snapshot + daily immutable S3 Object Lock (Compliance mode)
Cross-region replica: us-west-2; RTO target 4h / RPO target 15m (Tier-1)
Last successful restore drill: 2026-06-12 (see DR Drill report)

7. DATA CLASSIFICATION

ePHI / Restricted — Aurora + selected S3 buckets (customer-isolated keys)
Internal — engineering telemetry (no direct identifiers)
Public — marketing site only

8. KNOWN ARCHITECTURE NOTE (UW RELEVANT)

Regional OpenVPN path (BOS-R1) does not yet challenge Okta MFA on all admin groups. Compensating: IP allowlist + jump host. Target close: 2026-Q4.

Prepared by: Platform Security | Reviewed by: CISO Office